

ENTERPRISE SECURITY ASSESSMENT LAB

API Security Evidence Documentation Report

GraphQL User Data Query Testing Evidence

Professional Portfolio Edition - Authorized API Security Lab Evidence

Field	Details
Test Area	GraphQL data query
Result Type	Query testing
Evidence Report File	17-graphql-user-data-query-test-evidence-report.pdf
Testing Phase	GraphQL Resolver and Data Access Testing
Tool / Component	GraphQL Query / DVGA
OWASP / Security Mapping	API1/API3: Object and Property Level Authorization
Repository Path	02-api-security/reports/evidence/
Prepared For	GitHub recruiter portfolio documentation

This report documents one API Security evidence row as a standalone professional artifact. It includes the embedded screenshot, what it proves, the methodology context, command/workflow, sanitized output style, risk interpretation, remediation guidance, and publication redaction requirements.

1. Embedded Evidence Screenshot

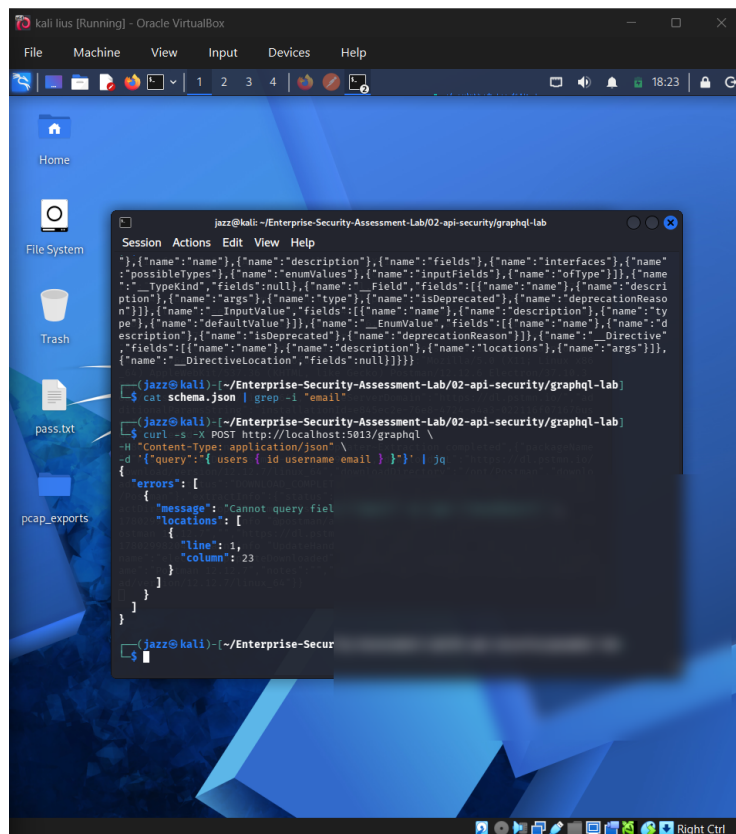


Figure 1 - Embedded screenshot evidence for: GraphQL data query

What this evidence proves

The evidence shows a GraphQL data query and response review. Sensitive values are blurred where needed.

Evidence handling note

The screenshot has been prepared for GitHub publication. Sensitive fields such as credentials, tokens, JWTs, cookies, personal data, host values, or other secrets are blurred or represented as redacted values where needed.

2. Assessment Context and Methodology Placement

Area	Value
Testing Phase	GraphQL Resolver and Data Access Testing
Tool / Component	GraphQL Query / DVGA
Assessment Objective	Test whether GraphQL queries return user data and whether resolver-level authorization controls are enforced.
Result Type	Query testing
OWASP / Security Mapping	API1/API3: Object and Property Level Authorization

Why this evidence matters

GraphQL authorization must be enforced at the resolver level. Even if the endpoint requires authentication, individual fields and objects still need access control.

Command / workflow used

```
Identify user-related query from schema
Submit query with selected fields
Review returned objects
Check whether data belongs to the authenticated or expected context
```

Sanitized output style

```
query {
  users {
    id
    email: <REDACTED>
    role: <REVIEWED>
  }
}
```

Response reviewed for overexposure and authorization behaviour

3. Professional Interpretation

This evidence row should be interpreted as: **Query testing**.

If GraphQL returns unauthorized user data, attackers may enumerate accounts, access private details, or bypass normal REST-style controls.

Assessor notes

This evidence should be interpreted based on whether the response shows authorized or unauthorized data.

How a recruiter or reviewer should read this evidence

The value of this evidence is not only the screenshot itself. The value is that it demonstrates a structured API security testing process: controlled lab setup, targeted testing, safe interpretation of results, and clear separation between confirmed vulnerabilities and controls that rejected attack attempts.

Finding interpretation

Where the evidence shows vulnerable behaviour, the report should explain the security impact, the affected object or workflow, and the remediation without publishing sensitive raw values.

4. Risk, Impact, and Remediation Guidance

Risk perspective

If GraphQL returns unauthorized user data, attackers may enumerate accounts, access private details, or bypass normal REST-style controls.

Recommended remediation / hardening actions

- Apply resolver-level authorization.
- Limit returned fields.
- Use field-level access control.
- Add query depth and complexity limits.
- Monitor sensitive GraphQL queries.

Validation guidance after remediation

- Repeat the same test workflow after remediation and compare the response behaviour.
- Confirm that sensitive data is no longer exposed in raw API responses.
- Confirm that unauthorized requests return secure error responses such as 401 or 403 where appropriate.
- Confirm that security controls are enforced server-side, not only in the frontend or client collection.

5. GitHub Publication and Redaction Guidance

Sensitive values to redact before public upload

- Emails.
- User IDs.
- Roles if sensitive.
- Tokens.
- Returned personal data.

General API evidence redaction checklist

- Blur JWT access tokens, bearer tokens, OAuth codes, cookies, and authorization headers.
- Blur email addresses, phone numbers, user IDs, vehicle IDs, order IDs, and private object identifiers.
- Do not upload Postman environment files containing live variables or secrets.
- Do not upload raw response exports containing personal data or secret-bearing values.
- Use placeholders such as , , and .

GitHub link format for 02-api-security/README.md

[GraphQL data query](./reports/evidence/17-graphql-user-data-query-test-evidence-report.pdf)

Final classification

This PDF is suitable for a public GitHub portfolio only after the embedded screenshot has been reviewed and sensitive values are confirmed blurred or removed.